

LEARNING RESOURCE GUIDE

ISC2 CCSP: Certified Cloud Security Professional (Aug 2026) | Professional Participant Workbook

SIEM, Log Capture and Analysis, and Threat Intelligence

Domain 5: Cloud Security Operations | ISC2 CCSP Exam Preparation

1. Learning Objectives

- By the end of this lecture, you will be able to explain the two core functions of a SIEM platform — aggregation and correlation — and why both are necessary for effective threat detection.
- By the end of this lecture, you will be able to identify the primary log sources in a cloud environment and describe what each contributes to the security monitoring picture.
- By the end of this lecture, you will be able to define threat intelligence and explain how it is integrated into a SIEM to improve detection capability.
- By the end of this lecture, you will be able to describe what Indicators of Compromise are and how they are used in real-time log correlation.
- By the end of this lecture, you will be able to explain why a SIEM must be treated as a living system requiring ongoing tuning, not a deployed product that operates autonomously.

2. Introduction

A regional bank operating across twelve countries generates approximately 600 million log events per day across its cloud infrastructure. Firewall denials, API calls, authentication events, database queries, application transactions, and network flow records — each one a data point, each one potentially irrelevant, and somewhere in that volume, the trail of an attacker who has been inside the network for three weeks. Finding it manually is not a strategy. Security Information and Event Management — SIEM — is the technology built specifically for this problem.

SIEM platforms serve two foundational purposes. First, they aggregate log data from across the environment into a single location, giving analysts one view instead of twelve. Second, they apply correlation rules and analytics to that aggregated data to surface events worth a human analyst's attention. The aggregation solves the access problem — you can see everything in one place. The correlation solves the signal problem — you see the pattern the events form together, not just the events in isolation.

What makes a SIEM significantly more powerful than a passive log aggregator is threat intelligence. When curated information about current attacker tools, infrastructure, and techniques is integrated into the SIEM, the correlation engine can automatically match incoming log events against known threat indicators. A connection to a known command-and-control server becomes an immediate alert rather than an unnoticed line in a firewall log. This lecture covers how these capabilities work together and what it takes to keep a SIEM effective over time.

3. Core Concepts Explained

3.1 SIEM Aggregation: Solving the Access Problem

Log aggregation is the foundational SIEM function. In a cloud environment, security-relevant events are generated across dozens of distinct systems and services: cloud provider audit logs, identity systems, network devices, applications, databases, and endpoint security tools. Each system has its own console, its own format, and its own retention policy. Without aggregation, an analyst investigating an incident must access each system individually, translate between formats, and mentally correlate timelines — a process that is slow, error-prone, and practically impossible at scale.

Business relevance: The speed of incident detection and response is directly related to how quickly analysts can access and correlate data. Every hour that a threat goes undetected is an hour of continued exposure. A centralised SIEM reduces the time from event to alert by making data accessible without manual system-by-system searching.

Practitioner angle: Log fidelity matters as much as volume. Logs that arrive too late, lack key fields, or are truncated create false confidence — you believe you have visibility you do not actually have. When designing logging architecture, be explicit about required fields, maximum acceptable latency from event to SIEM ingestion, and retention periods. In regulated environments, retention requirements are often specified in compliance frameworks and are non-negotiable.

3.2 Cloud Log Sources and What They Provide

Cloud environments have a distinct set of log sources that differ meaningfully from on-premises environments. Understanding what each source provides is essential for designing an effective monitoring architecture.

Cloud provider audit logs — AWS CloudTrail, Azure Activity Log, GCP Cloud Audit Logs — record every API call made in the account: who called it, from where, when, and what the result was. These logs are the most important source for detecting account compromise, privilege escalation, and configuration changes. They are the equivalent of a detailed access log for the entire management plane.

VPC and network flow logs record traffic at the network level: source IP, destination IP, port, protocol, and whether the connection was allowed or denied. These logs are essential

for detecting lateral movement, anomalous outbound connections, and network-level reconnaissance.

Identity and access management logs capture authentication events, multi-factor authentication bypasses, role assumption, and permission changes. These are among the highest-value sources for detecting account compromise and insider threats.

Application logs capture business logic events — login attempts, data access, transaction processing, API calls to external services. Their value depends heavily on what the application logs and how consistently it does so. Poorly instrumented applications are significant blind spots.

Security tool outputs from firewalls, IDS/IPS systems, and vulnerability scanners provide pre-analysed signals that supplement the raw log data.

3.3 SIEM Correlation: Solving the Signal Problem

Aggregation without correlation produces a very expensive log storage system. Correlation is what makes a SIEM a security tool. Correlation rules define patterns across multiple log sources that, when matched, generate an alert. A single failed login attempt is noise. A hundred failed login attempts against 50 different accounts in 10 minutes from the same IP address is a brute-force attack. Correlation rules make that distinction automatically.

More sophisticated correlation combines events across time and systems. A successful login following 50 failed attempts, combined with an immediate privilege escalation and a new API key creation, is a pattern that no individual event reveals but that a well-designed correlation rule surfaces immediately.

The hospital monitoring analogy applies directly here. Each patient in intensive care has multiple sensors: heart rate, blood pressure, oxygen saturation, temperature. No one stares at each monitor individually. The monitoring system watches all of them simultaneously, correlates readings against clinical thresholds and patterns, and alerts the nurse when the combination of readings indicates deterioration. A single reading in isolation might not be alarming. The pattern across readings tells a different story. SIEM correlation works exactly this way for security events.

3.4 Threat Intelligence: Making Correlation Contextually Aware

Threat intelligence is curated, contextual information about current attacker tactics, techniques, procedures, and infrastructure. It takes several forms: lists of known malicious IP addresses and domain names, file hashes associated with malware samples, patterns characterising specific attacker groups, and descriptions of attack techniques mapped to frameworks such as MITRE ATT&CK.

When threat intelligence is integrated into a SIEM, the correlation engine gains the ability to match incoming events against known threat indicators automatically. A connection from an internal host to an IP address on a threat intelligence blocklist triggers an immediate alert. A DNS query for a domain associated with a known command-and-control server is

flagged in real time. Without threat intelligence integration, these events look like ordinary network traffic.

Business relevance: Threat intelligence allows a SIEM to benefit from the aggregated knowledge of every organisation that has shared information about threats they have encountered. A small organisation protecting its own environment gains detection capabilities built from incidents at organisations much larger than itself. This is a significant force multiplier for teams with limited resources.

3.5 Indicators of Compromise

Indicators of Compromise (IOCs) are the specific technical artefacts that threat intelligence produces: IP addresses associated with malicious infrastructure, domain names used by command-and-control servers, file hashes matching known malware samples, email sender addresses used in phishing campaigns, and URL patterns associated with known attack infrastructure.

IOC integration in a SIEM means that whenever a log event references a known IOC — an outbound connection to a known bad IP, a DNS query for a known bad domain, a file hash matching known malware — the SIEM generates an alert automatically. This is the most direct form of threat intelligence integration and the most immediately actionable.

Practitioner angle: IOC lists require regular updating. An IOC that was valid six months ago may reference infrastructure that has since been taken down or repurposed. An outdated IOC list generates false positives and erodes analyst confidence in the SIEM's output. Building automated IOC feed refresh into the SIEM architecture is not optional — it is a prerequisite for the IOC integration to remain useful.

3.6 The SIEM as a Living System

The most common mistake organisations make with SIEM deployment is treating it as a product that works once it is installed. A SIEM is a living system. The correlation rules that made sense at deployment may no longer reflect the current environment or threat landscape. New log sources added to the environment must be onboarded into the SIEM. Alert thresholds must be tuned based on operational experience. Threat intelligence feeds must be refreshed. New attacker techniques require new detection rules.

A SIEM that was state-of-the-art at deployment and has never been updated provides progressively less coverage over time while giving the security team the false impression that they are monitoring effectively. The operational cost of SIEM maintenance is real but unavoidable.

4. Cloud Log Sources: Comparison Table

Log Source	What It Records	Primary Detection Value	Key Risk if Missing
AWS CloudTrail /	Every API call: who,	Account	Entire management

Azure Activity Log	when, from where, result	compromise, privilege escalation, config changes	plane invisible to security monitoring
VPC / Network Flow Logs	Traffic: source IP, destination IP, port, protocol, allow/deny	Lateral movement, anomalous outbound, reconnaissance	Network-level threats undetectable
IAM / Identity Logs	Authentication events, MFA bypass, role assumption, permission changes	Credential compromise, insider threats, privilege abuse	Account-based attacks go undetected
Application Logs	Business logic events: logins, data access, API calls, transactions	Application-layer attacks, data access anomalies	Application attack surface completely blind
Security Tool Outputs	Pre-analysed alerts from firewalls, IDS/IPS, vulnerability scanners	Contextual enrichment, known-signature detection	Loss of pre-filtered high-confidence signals
DNS Logs	Domain name resolution requests and responses	Command-and-control communication, data exfiltration via DNS	DNS-based attacks and C2 channels undetected

5. Case Study

Case Study: A financial services organisation in the United Kingdom integrated a commercial threat intelligence feed into their SIEM platform. Within the first month, the platform automatically flagged outbound connections from three internal hosts to IP addresses the threat intelligence feed had identified as command-and-control servers for a banking trojan family. The connections had been occurring for eleven days before the threat intelligence integration was activated. Without the threat intelligence context, those connections appeared as ordinary outbound HTTPS traffic to cloud-hosted IPs — a pattern indistinguishable from legitimate SaaS application traffic in the network flow logs. With the integration active, the first connection after activation generated an automatic high-severity alert. The incident response team contained the compromise within four hours of the alert. The eleven days of prior activity were recovered from archived logs and used to establish the full scope of what had been accessed. The lesson: threat intelligence integration does not just improve future detection. It can also make previously invisible historic activity visible when applied retroactively to archived log data.

6. Analogy and Memory Anchor

Think of a SIEM as a hospital's patient monitoring system, scaled to an entire organisation.

Each patient in an intensive care unit has sensors measuring multiple vital signs simultaneously. No nurse stares at each monitor individually all night. The system watches all of them, correlates the readings against clinical thresholds, and alerts when the pattern — not any single reading — indicates deterioration. A SIEM does exactly this for security events: individual log entries are vital signs, correlation rules are the clinical thresholds, and the alert is the nurse's alarm. Without the system, the nurse would have to check every patient manually. With it, they respond only when the pattern says act.

Threat intelligence memory anchor: Threat intelligence is a neighbourhood watch at city scale. Every organisation that shares what an attacker used against them contributes to a shared knowledge base that every other organisation can act on. Your SIEM checking incoming traffic against known bad IPs is your organisation benefiting from every incident that has ever been documented and shared — without having to experience each one yourself.

7. Exam Focus

ISC2 tests SIEM and threat intelligence primarily through scenario questions that ask you to identify what a SIEM would or would not detect, or to evaluate logging architecture adequacy.

- Know the difference between aggregation (centralising log data) and correlation (identifying patterns across that data).
- Understand that log fidelity — the completeness and timeliness of log data — is as important as log volume.
- Know what Indicators of Compromise are and how IOC integration into a SIEM works in practice.
- Understand that threat intelligence benefits organisations of all sizes, not just large enterprises.
- Common distractor: 'A SIEM with threat intelligence integration will automatically detect all attacks.' Incorrect — a SIEM detects what it has rules and intelligence to detect. Novel attacks not covered by existing rules or IOC lists can still evade detection.
- Know that SIEMs require ongoing maintenance: log source onboarding, rule tuning, threat intelligence feed refresh, and threshold adjustment.
- Understand that AWS CloudTrail and Azure Activity Log are management-plane logs — they record API calls, not application data.

8. Key Terms Glossary

SIEM (Security Information and Event Management): A platform that aggregates log data from across an environment and applies correlation rules and analytics to identify security-relevant patterns.

Log Aggregation: The process of collecting log data from multiple systems and sources into a central repository.

Correlation Rule: A defined pattern across log events that, when matched, generates a SIEM alert.

Threat Intelligence: Curated, contextual information about current attacker tactics, techniques, procedures, and infrastructure used to improve detection capability.

Indicator of Compromise (IOC): A specific technical artefact — IP address, domain, file hash, URL — associated with known malicious activity.

AWS CloudTrail: AWS's management-plane audit log service, recording every API call in the account with actor, source, timestamp, and result.

VPC Flow Log: A cloud network log recording traffic flows at the virtual network level, including source/destination IP, port, protocol, and allow/deny decision.

Command-and-Control (C2): Infrastructure used by attackers to remotely manage compromised systems; C2 domain names and IPs are common IOCs.

Log Fidelity: The completeness, accuracy, and timeliness of log data — the degree to which logs accurately represent the events they record.

MITRE ATT&CK: A publicly maintained framework cataloguing attacker tactics, techniques, and procedures, widely used to structure threat intelligence.

Alert Fatigue: The condition where analysts begin ignoring or dismissing alerts due to excessive volume or high false positive rates, reducing effective detection capability.

Log Retention: The period for which log data is stored, governed by operational needs, regulatory requirements, and investigation timelines.

9. Quick Revision Checklist

- ☐ I can explain what log aggregation achieves and why it matters for investigation speed.
- ☐ I can describe the two core SIEM functions: aggregation and correlation.
- ☐ I can name five cloud log sources and describe what each provides.

- ☐ I understand why log fidelity (completeness and timeliness) matters as much as log volume.
- ☐ I can define threat intelligence and describe at least three forms it takes.
- ☐ I can explain what an IOC is and how IOC integration into a SIEM works.
- ☐ I understand why threat intelligence benefits small organisations as well as large ones.
- ☐ I can explain why a SIEM must be continuously maintained and tuned, not simply deployed.
- ☐ I know that AWS CloudTrail records management-plane API calls, not application data.
- ☐ I understand the risk of alert fatigue and how it arises from poor SIEM tuning.

10. Practice Questions

Scenario 1 (Questions 1–3): A manufacturing company has deployed a SIEM that aggregates logs from its cloud environment. The SIEM has been operational for 18 months with its initial correlation rules unchanged. The company recently migrated three legacy applications to the cloud but has not onboarded their logs into the SIEM. The security team believes their monitoring is comprehensive because the SIEM dashboard shows normal alert levels.

Q1. What is the MOST significant security risk associated with this SIEM configuration?

- A. The SIEM's storage capacity may be insufficient for the increased log volume from the migrated applications.
- B. The three migrated applications represent an unmonitored attack surface because their logs are not ingested into the SIEM.**
- C. The 18-month-old correlation rules will generate excessive false positives against the migrated application logs.
- D. The SIEM dashboard's normal alert levels confirm that the monitoring configuration is adequate.

Answer: B

A — Incorrect: Incorrect. Storage capacity is an operational concern but is not the most significant security risk. The risk is unmonitored attack surface, not storage.

B — Correct: Correct. Any system whose logs are not ingested into the SIEM is effectively invisible to the security monitoring function. If an attacker compromises one of the three migrated applications, the SIEM will generate no alerts because it has no data from those applications to correlate.

C — Incorrect: Incorrect. The problem is not that correlation rules will generate false positives against the new logs — the problem is that the new logs are not present in the SIEM at all.

D — Incorrect: Incorrect. Normal alert levels in a SIEM that is not monitoring three applications simply means those applications are not being monitored. It is not confirmation of adequacy.

Q2. The security team plans to onboard the migrated application logs into the SIEM. Which log quality attribute is MOST important to validate before onboarding?

A. The total volume of log events generated per day.

B. Whether the logs are generated in JSON format.

C. Whether the logs contain the required fields (user identity, timestamp, action, source IP) with sufficient completeness and timeliness.

D. Whether the log storage is encrypted at rest.

Answer: C

A — Incorrect: Incorrect. Volume is a capacity planning concern, not a quality attribute. A high volume of incomplete logs is worse than a lower volume of complete, well-structured logs.

B — Incorrect: Incorrect. JSON is a common format for cloud logs, but format is less important than content. Logs in any parseable format that contain the required fields are more valuable than JSON logs that lack key fields.

C — Correct: Correct. Log fidelity — completeness of required fields, accuracy of timestamps, and timeliness of delivery to the SIEM — determines whether the logs can actually be used for detection and investigation. Logs missing user identity or timestamps cannot support meaningful correlation.

D — Incorrect: Incorrect. Encryption at rest is a data protection control, not a log quality attribute for detection purposes. It does not affect whether the logs are useful for security monitoring.

Q3. The SIEM team proposes updating the correlation rules as part of the onboarding project. Which action should ALSO be included to ensure the rules remain effective over time?

A. Set a calendar reminder to review the rules every five years.

B. Configure the SIEM to automatically delete correlation rules that do not generate alerts within 90 days.

C. Establish a structured process for ongoing rule review and tuning based on analyst feedback, new threat intelligence, and environment changes.

D. Limit correlation rules to a maximum of 20 to prevent performance degradation.

Answer: C

A — Incorrect: Incorrect. A five-year review cycle is far too infrequent for a threat landscape that evolves continuously. Correlation rules should be reviewed at least annually and whenever significant environment changes occur.

B — Incorrect: Incorrect. Rules that do not generate alerts may be detecting a threat type that simply has not occurred in the environment. Deleting them removes coverage against threats that have not yet been seen.

C — Correct: Correct. Effective SIEM operation requires a living rule management process. Analyst feedback identifies false positives and false negatives. Threat intelligence highlights new attack patterns requiring new rules. Environment changes introduce new log sources and behaviours that existing rules may not correctly interpret.

D — Incorrect: Incorrect. The appropriate number of correlation rules is determined by the environment's complexity and risk profile, not by an arbitrary limit.

Q4. A SIEM operator discovers that the SIEM's threat intelligence feed has not been refreshed for four months. What is the MOST significant consequence?

A. The SIEM will generate an error and stop processing log events until the feed is refreshed.

B. IOC matching will be based on outdated threat data, potentially missing connections to current attacker infrastructure and generating false positives against decommissioned IOCs.

C. The SIEM's log aggregation function will be unaffected, but correlation rules will stop working.

D. The organisation will be in violation of GDPR for failing to maintain current threat intelligence.

Answer: B

A — Incorrect: Incorrect. SIEM platforms continue processing log events regardless of the currency of the threat intelligence feed. The consequence is reduced detection quality, not a system failure.

B — Correct: Correct. An outdated threat intelligence feed creates two problems: it may miss connections to attacker infrastructure that has been identified in the past four months, and it may flag connections to infrastructure that was malicious four months ago but has since been decommissioned and repurposed — generating false positives that erode analyst confidence.

C — Incorrect: Incorrect. Log aggregation and correlation rule execution are separate from threat intelligence feed currency. The SIEM continues to function; the quality of IOC matching degrades.

D — Incorrect: Incorrect. GDPR governs the processing of personal data. It does not specify threat intelligence feed refresh requirements. There is no direct GDPR violation from an outdated threat intelligence feed.

Q5. Which of the following BEST describes the difference between AWS CloudTrail and VPC Flow Logs in terms of what they record?

A. CloudTrail records network traffic; VPC Flow Logs record API calls.

B. CloudTrail records management-plane API calls (who did what to the AWS environment); VPC Flow Logs record network-level traffic flows (source IP, destination IP, port, protocol).

C. CloudTrail is available only in AWS GovCloud; VPC Flow Logs are available in all AWS regions.

D. CloudTrail records only security-related events; VPC Flow Logs record all operational events.

Answer: B

A — Incorrect: Incorrect. This reverses the correct descriptions. CloudTrail records API calls; VPC Flow Logs record network traffic.

B — Correct: Correct. CloudTrail captures management-plane activity — every API call made in the AWS account, including who made it, from where, when, and whether it succeeded. VPC Flow Logs capture network-level data — traffic flows at the virtual network interface level. They answer different questions and provide complementary visibility.

C — Incorrect: Incorrect. Both CloudTrail and VPC Flow Logs are available in all commercial AWS regions, not only GovCloud.

D — Incorrect: Incorrect. CloudTrail records all API calls, not only security-related ones. It is a comprehensive audit log of management-plane activity.

Q6. A small retail company with a 5-person IT team is considering whether to invest in a commercial threat intelligence feed for their SIEM. A team member argues that threat intelligence feeds are only valuable for large enterprises because small organisations are not targeted. What is the MOST accurate response to this argument?

A. The argument is correct; threat intelligence is most valuable for large financial institutions that are primary targets.

B. The argument is incorrect; attackers reuse infrastructure, tools, and techniques across many targets, and a small organisation with threat intelligence integration benefits from detection capabilities built across incidents at organisations of all sizes.

C. The argument is partially correct; threat intelligence feeds are only cost-effective for organisations generating more than 1 billion log events per day.

D. The argument is correct for IP-based IOCs but incorrect for domain-based IOCs, which apply equally to organisations of all sizes.

Answer: B

A — Incorrect: Incorrect. Small organisations are frequently targeted, often specifically because they are assumed to have weaker security. The argument's premise — that small organisations are not targeted — is factually incorrect.

B — Correct: Correct. Threat intelligence is a force multiplier that does not require organisational size to be effective. Attackers routinely reuse command-and-control infrastructure, malware families, and attack techniques across many targets. A small organisation with an integrated threat intelligence feed benefits from the detection capabilities built from incidents affecting organisations much larger than itself.

C — Incorrect: Incorrect. The value of threat intelligence is not correlated with log volume. It depends on whether the threat actors targeting the organisation use infrastructure and techniques that have been documented in the feed.

D — Incorrect: Incorrect. This distinction between IP-based and domain-based IOCs is not an accurate characterisation. Both types of IOCs apply equally regardless of organisational size.

Q7. An analyst reviewing SIEM alerts notices that outbound connections from an internal server to a specific IP address are generating high-severity alerts due to a threat intelligence IOC match. The analyst confirms the IP is in the threat intelligence feed as a known command-and-control server. What is the CORRECT interpretation of this finding?

A. The server's traffic to that IP is not suspicious because the connection may be to a legitimate cloud service that shares infrastructure with the flagged IP.

B. The IOC match is a confirmed indicator of compromise requiring immediate investigation; the server should be treated as potentially compromised pending analysis.

C. IOC matches are low-confidence indicators and should be treated as informational only until corroborated by an IDS signature.

D. The finding confirms that the threat intelligence feed is functioning correctly but does not necessarily indicate an active compromise.

Answer: B

A — Incorrect: Incorrect. While cloud services sometimes share IP ranges with other services, a connection matching a known command-and-control IOC is a high-priority finding. The correct response is investigation, not dismissal based on a theoretical alternative explanation.

B — Correct: Correct. An IOC match against a known command-and-control server IP is a significant finding. The server should be treated as potentially compromised and subjected to immediate investigation — log review, process analysis, and containment evaluation — while the investigation proceeds.

C — Incorrect: Incorrect. IOC matches against known malicious infrastructure are not low-confidence indicators. They represent the direct comparison of observed activity against documented attacker infrastructure. The absence of an IDS signature does not reduce their significance.

D — Incorrect: Incorrect. Confirming feed functionality is a side effect of an IOC match, not its primary significance. The primary significance is that an internal server is communicating with known attacker infrastructure.

Scenario 2 (Questions 8–10): A cloud security architect is designing the logging and SIEM architecture for a new cloud environment that will process customer payment data. The organisation is subject to PCI DSS compliance. The architect must decide which log sources to include and what retention period to enforce.

Q8. Which log source is MOST critical to include in the SIEM configuration for detecting management-plane attacks such as privilege escalation and unauthorised configuration changes?

A. Application performance monitoring logs

B. Database query performance logs

C. Cloud provider audit logs (AWS CloudTrail or equivalent)

D. Operating system patch management logs

Answer: C

A — Incorrect: Incorrect. Application performance monitoring logs capture response times, error rates, and resource utilisation. They do not record who performed management actions or what configuration changes were made.

B — Incorrect: Incorrect. Database query performance logs record query execution times and resource usage. They do not capture management-plane activity.

C — Correct: Correct. Cloud provider audit logs record every API call made in the account — including privilege escalation, role assumption, security group modifications, and IAM policy changes. For detecting management-plane attacks, there is no higher-value log source.

D — Incorrect: Incorrect. Patch management logs record which patches were applied and when. They have value for compliance reporting but do not capture real-time management-plane activity.

Q9. PCI DSS requires that audit logs be retained for at least 12 months, with the most recent three months immediately available for analysis. An architect proposes storing all logs in a cold storage tier that requires 24-48 hours for retrieval. How does this affect PCI DSS compliance?

A. It fully satisfies PCI DSS requirements because 24-48 hour retrieval is considered immediately available.

B. It partially satisfies PCI DSS requirements; the 12-month total retention is met, but the requirement that the most recent three months be immediately available is not met.

C. It does not affect PCI DSS compliance because log retention requirements apply only to application logs, not infrastructure logs.

D. It exceeds PCI DSS requirements because cold storage provides better data integrity than hot storage.

Answer: B

A — Incorrect: Incorrect. PCI DSS specifically requires that the most recent three months of logs be available for immediate analysis. A 24-48 hour retrieval time does not satisfy the immediacy requirement.

B — Correct: Correct. The 12-month total retention is met by cold storage. However, the PCI DSS requirement that the most recent three months be immediately available is not met by a tier with 24-48 hour retrieval. A two-tier architecture — three months in hot storage, nine months in cold storage — would satisfy both requirements.

C — Incorrect: Incorrect. PCI DSS log retention requirements apply to all audit logs relevant to the cardholder data environment, including infrastructure and network logs, not only application logs.

D — Incorrect: Incorrect. Storage tier selection is driven by access requirements and cost, not data integrity. Cold storage does not inherently provide better data integrity than hot storage.

Q10. The architect integrates a commercial threat intelligence feed into the SIEM. During the first week, the feed generates 45 IOC match alerts, all of which the SOC team investigates and confirms as false positives related to a legitimate payment

processor's IP range that overlaps with flagged infrastructure. What is the APPROPRIATE response?

- A. Disconnect the threat intelligence feed because it is generating too many false positives.
- B. Add the payment processor's confirmed legitimate IP ranges to an exclusion list in the IOC matching configuration, and report the false positives to the threat intelligence provider.**
- C. Reduce the SIEM's alert sensitivity for all IOC matches to reduce the false positive volume.
- D. Replace the commercial threat intelligence feed with a free open-source feed to reduce costs associated with a low-quality feed.

Answer: B

A — Incorrect: Incorrect. Disconnecting the feed removes the entire threat intelligence detection capability because of a specific, resolvable false positive issue. The appropriate response is to resolve the specific issue.

B — Correct: Correct. The false positives are caused by a specific, identifiable overlap between a legitimate payment processor's IP range and flagged infrastructure. Adding that IP range to an exclusion list resolves the false positive without removing the broader threat intelligence capability. Reporting the false positives to the provider improves the feed quality for all subscribers.

C — Incorrect: Incorrect. Reducing overall IOC alert sensitivity suppresses legitimate threat detections as well as false positives. The appropriate action is targeted exclusion of the specific known-good IP range, not broad sensitivity reduction.

D — Incorrect: Incorrect. The false positive is caused by a specific IP range overlap, not by the quality of the commercial feed. Switching to a free feed does not resolve the underlying issue and may reduce overall feed quality.